15.3 Policies for zero trust

As ACME expanded its use of policy-based authorization, the security and identity teams weren't the only groups discovering the benefits of expressing rules in policies. Application teams quickly saw the value of defining their service-specific logic in a policy store, but it didn't take long before other parts of the organization noticed a gap. Some rules were too broad to belong to a single application but not universal enough to be considered foundational security policies. These were the rules that applied to groups of systems, departments, or cross-functional workflows.

Engineering was the first to encounter this. Various product teams had their own deployment pipelines, but all of them wanted the same guarantees: Deploy only during business hours, require the on-call engineer for late-night changes, and prevent releases when incident severity was high. None of these rules were "security policies" in the enterprise-wide sense, and they weren't tied to the logic of a single service. They were operational rules that spanned many systems. Rather than embed them independently into every deployment tool, engineering chose to express them as a shared set of policies that all pipelines could reference.

Other groups followed. Finance established shared policies to regulate how different categories of employees could access sensitive reports across multiple systems. Operations outlined maintenance-window rules that applied to various internal tools. Support teams crafted policies governing access to customer data based on role and shift. In each case, these were neither core enterprise requirements nor single-application rules—they existed in the space between.

ACME formalized this emerging pattern into a distinct category: shared operational policies. These policies were owned by functional groups—engineering, operations, finance, support—and applied to specific sets of systems or workflows. They captured cross-team operational rules without overreaching into enterprise-wide mandates or bloating individual application policy stores. This middle layer became essential for defining responsibilities that cut across the organization but did not fall under the security team or individual product teams.